LAPORAN TUGAS 6: MIDDLEWARE DAN HAK AKSES ADMIN

Genre dan Author - Sistem Informasi Penjualan Buku (Book Sales)

Nama : Muhamad Aditia
Nim : 0110224213
Rombel : TI02 STT-NF

1. Tujuan

Mengatur hak akses pada API menggunakan middleware. Data Genre dan Author (Read All dan Show) dapat diakses oleh semua orang tanpa login, sedangkan Create, Update, dan Destroy hanya dapat diakses oleh admin. Pengujian dilakukan dengan Postman.

2. Konsep Singkat

Konsep	Penjelasan
Autentikasi	Memverifikasi identitas pengguna. Pada tugas ini pengguna login dengan email dan password, lalu menerima token.
Otorisasi	Menentukan apa yang boleh dilakukan pengguna setelah identitasnya terverifikasi, berdasarkan kolom role (admin atau user).
Middleware	Lapisan yang memeriksa request sebelum sampai ke Controller. Dipakai untuk memeriksa token (auth:sanctum) dan role admin (AdminMiddleware).
RBAC	Hak akses ditentukan oleh peran (role). Role admin boleh menambah, mengubah, dan menghapus data, sedangkan role user hanya boleh membaca.

Password disimpan dalam bentuk hash, bukan teks asli. Token diperoleh dari endpoint login dan dikirim pada header Authorization dengan format Bearer.

3. Pemenuhan Instruksi Tugas

Poin	Instruksi	Pelaksanaan
2.1	Read All dan Show dapat diakses semua orang	Route index dan show untuk genres dan authors berada di luar middleware, sehingga dapat diakses tanpa token.
2.2	Create, Update, Destroy hanya admin	Route store, update, dan destroy berada di dalam grup auth:sanctum dan AdminMiddleware.
3	Testing dengan Postman	Setiap aturan akses diuji dengan Postman (lihat bagian 5).
4	Push ke GitHub	Proyek diunggah ke folder book-sales-6 (lihat bagian 6).

Pendukung: kolom role ditambahkan pada tabel users melalui migration, dan UserSeeder membuat dua akun, yaitu admin@example.com (role admin) dan user@example.com (role user). AuthController menyediakan register, login, me, dan logout.

4. Routing dan Middleware

4.1 routes/api.php

```php
<?php

use App\Http\Controllers\AuthController;
use App\Http\Controllers\AuthorController;
use App\Http\Controllers\GenreController;
use App\Http\Middleware\AdminMiddleware;
use Illuminate\Support\Facades\Route;

// Semua route di file ini otomatis berawalan /api

// ------------------------------------------------------------
// 1. Autentikasi (bebas diakses)
// ------------------------------------------------------------
Route::post('/register', [AuthController::class, 'register']);
Route::post('/login', [AuthController::class, 'login']);

// Dibutuhkan oleh middleware auth: jika belum login, Laravel mengarahkan ke route
// bernama "login". Route ini membalas JSON 401 supaya tidak muncul error HTML.
Route::get('/login', function () {
    return response()->json([
        'success' => false,
        'message' => 'Silakan login terlebih dahulu',
        'data'    => null,
    ], 401);
})->name('login');

// ------------------------------------------------------------
// 2. Read All dan Show: bisa diakses SEMUA ORANG (tanpa login)
// ------------------------------------------------------------
Route::apiResource('genres', GenreController::class)->only(['index', 'show']);
Route::apiResource('authors', AuthorController::class)->only(['index', 'show']);

// ------------------------------------------------------------
// 3. Wajib login (token)
// ------------------------------------------------------------
Route::middleware('auth:sanctum')->group(function () {
    Route::get('/me', [AuthController::class, 'me']);
    Route::post('/logout', [AuthController::class, 'logout']);

    // ------------------------------------------------------------
    // 4. Create, Update, Destroy: HANYA ADMIN
    // ------------------------------------------------------------
    Route::middleware(AdminMiddleware::class)->group(function () {
        Route::apiResource('genres', GenreController::class)->except(['index', 'show']);
        Route::apiResource('authors', AuthorController::class)->except(['index', 'show']);
    });
});
```

4.2 AdminMiddleware

Middleware ini memeriksa role pengguna. Jika bukan admin, server mengembalikan JSON dengan status 403.

```php
<?php

namespace App\Http\Middleware;

use Closure;
use Illuminate\Http\Request;
use Symfony\Component\HttpFoundation\Response;

class AdminMiddleware
{
    // Hanya user dengan role "admin" yang boleh lanjut ke Controller.
    public function handle(Request $request, Closure $next): Response
```

```
    {
        $user = $request->user();

        if (!$user || $user->role !== 'admin') {
            return response()->json([
                'success' => false,
                'message' => 'Akses ditolak. Hanya admin yang boleh mengakses.',
                'data'    => null,
            ], 403);
        }

        return $next($request);
    }
}
```

5. Pengujian dengan Postman

Token diperoleh dari POST /api/login, lalu dipasang pada tab Authorization dengan tipe Bearer Token.

Method	URL	Akses	Status
GET	/api/genres, /api/genres/1	Tanpa token	200 OK
GET	/api/authors, /api/authors/1	Tanpa token	200 OK
POST	/api/genres	Tanpa token	401 Unauthorized
POST	/api/login	Akun user biasa	200 OK (token)
POST	/api/genres	Token user biasa	403 Forbidden
POST	/api/login	Akun admin	200 OK (token)
POST	/api/genres	Token admin	201 Created
PUT	/api/genres/{id}	Token admin	200 OK
DELETE	/api/genres/{id}	Token admin	200 OK

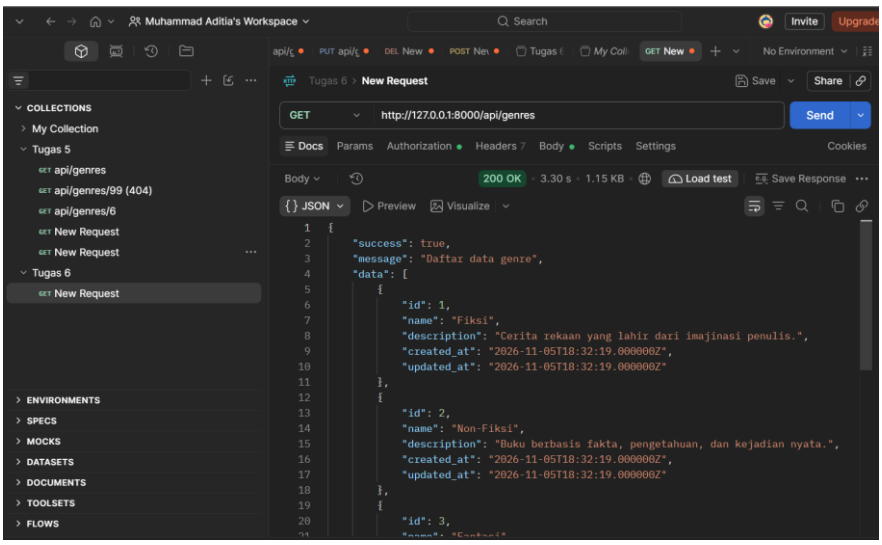
```
PS C:\xampp_baru\htdocs\Framework-Laravel\book-sales-6> php artisan route:list --path=api

  GET|HEAD        api/authors ..... authors.index › AuthorController@index
  POST            api/authors ..... authors.store › AuthorController@store
  GET|HEAD        api/authors/{author} ..... authors.show › AuthorController@show
  PUT|PATCH       api/authors/{author} ..... authors.update › AuthorController@update
  DELETE          api/authors/{author} ..... authors.destroy › AuthorController@destroy
  GET|HEAD        api/genres ..... genres.index › GenreController@index
  POST            api/genres ..... genres.store › GenreController@store
  GET|HEAD        api/genres/{genre} ..... genres.show › GenreController@show
  PUT|PATCH       api/genres/{genre} ..... genres.update › GenreController@update
  DELETE          api/genres/{genre} ..... genres.destroy › GenreController@destroy
  POST            api/login ..... AuthController@login
  GET|HEAD        api/login ..... login › routes/api.php:19
  POST            api/logout ..... AuthController@logout
  GET|HEAD        api/me ..... AuthController@me
  POST            api/register ..... AuthController@register

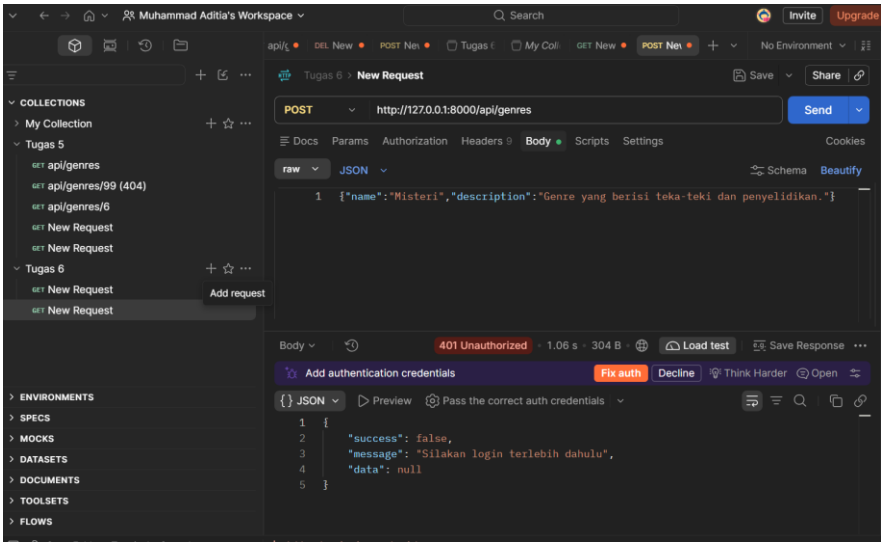
                                                    Showing [15] routes

PS C:\xampp_baru\htdocs\Framework-Laravel\book-sales-6>
```

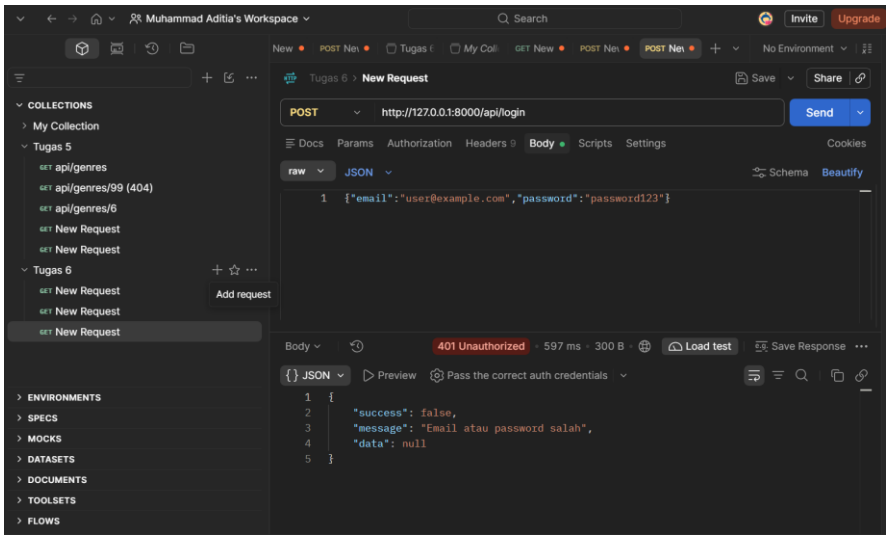
Gambar 1. Daftar route API



Gambar 2. Read All dapat diakses tanpa login



Gambar 3. Create ditolak tanpa token



Gambar 4. Create ditolak untuk user biasa

6. GitHub

Link repository: https://github.com/muhammadaditia433/Framework-Laravel/tree/main/book-sales-6

File yang dikumpulkan: routes/api.php.

7. Kesimpulan

Dengan middleware, akses ke API dapat dibatasi tanpa mengubah Controller. Data dapat dibaca oleh siapa saja, sedangkan perubahan data hanya dapat dilakukan oleh admin yang sudah login. Pengujian di Postman membuktikan bahwa request tanpa token ditolak dengan 401, request dari user biasa ditolak dengan 403, dan request dari admin diterima.